

电子取证中的热点难点问题

丁丽萍

中国科学院软件研究所

提纲

➡ 概况

- 研究领域
- 热点难点问题



计算机取证OR电子取证OR数据取证

科学地运用提取和证明方法，对于从电子数据源提取的电子证据进行保护（preservation）、收集(collection)、验证（validation）、鉴定（identification）、分析（analysis）、解释（interpretation）、存档（documentation）和出示（presentation），以有助于进一步的犯罪事件重构或者帮助识别某些与计划操作无关的非授权性活动。

信息安全解决事前的防护问题，取证解决事后究责问题
新诉讼法的提法是“电子数据”（刑事诉讼法P37 民事诉讼法P22）

计算机取证的产生和发展

- 1991年，在美国召开的国际计算机专家会议上首次提出了计算机取证（Computer Forensics）这一术语
- 1993年、1995年、1996年和1997年分别在美国和澳大利亚、新西兰召开了以计算机取证为主题的国际会议

这些都标志着计算机取证作为一个研究领域的诞生。



发 展

- 奠基时期
- 初步发展时期
- 理论完善时期

从总体上看，2000年之前的计算机取证研究主要侧重于取证工具的研究，2000年以后，开始了对计算机取证基础理论的研究。



奠基时期

- 时间：1984年至九十年代中期。
- 事件：
 - ✎ FBI成立了计算机分析响应组（CART）。
 - ✎ 数字取证科学工作组（SWGDE），这个小组首先提出了计算机潜在证据（latent evidence on a computer）的概念，形成了计算机取证概念的雏形。
 - ✎ 计算机取证技术工作组（TWGDE）：更多地和技术层面上对“数据取证”技术进行研究。
 - ✎ 科学工作组（SWG_s）的发展。
- 特点：公布了有关数字证据的概念、标准和实验室建设的原则等。截至1995年，美国48%的司法机关建立起了自己的计算机取证实验室。



初步发展时期

- 时间：九十年代中期至九十年代末期。
- 典型的计算机取证产品：
 - ❖ Encase：美国Guidance软件公司开发，用于证据数据的收集和分析。
 - ❖ DIBS：由美国计算机取证公司开发，对数据进行镜像的备份系统。
 - ❖ Flight Server：由英国Vogon公司开发。用于证据数据的收集和分析。
 - ❖ 其他工具：密码破解工具、列出磁盘上所有分区的LISTDRV、软盘镜像工具DISKIMAG、在特定的逻辑分区上搜索未分配的或者空闲的空间的工具FREESECS等等。



理论完善时期

- 时间：九十年代末期至现在
- 计算机取证的概念及过程模型被充分研讨
- 较为典型的五类模型：
 - ❖ 基本过程模型
 - ❖ 事件响应过程模型
 - ❖ 法律执行过程模型
 - ❖ 过程抽象模型
 - ❖ 其他模型
- 学科体系建设



数字取证国际会议动态

- 2001年至2003年召开的国际第13、14、15届FIRST (Forum of Incident Response and Security Teams) 网络安全年会，连续以计算机网络取证，也即数字取证为主题，研讨了网络安全应急响应策略中的证据获取与事件重建技术。它涵盖了数字取证的定义、工具及方法介绍，其中，数字证据的发现、文件系统的内部结构、Windows系统的取证分析以及取证协议与步骤的标准化等问题讨论得十分热烈。
- DFRWS (Digital Forensics Research Workshop) 每年一次，专门针对计算机取证和电子证据的相关技术问题进行了研讨。
- E-forensic是2008年开始举办的电子辨析技术研讨会年会。



研究数字取证的强国

- 美国：最早开展研究，有很多科研机构、大学和司法部门在积极从事这方面的研究
- 英国：比较早开展取证研究，特别是在和恐怖分子的斗争中很有经验
- 澳大利亚：近年来的研究很有成效，2008年年初开始组织e-forensics国际会议
- 韩国：早在1995年，韩国警方就组建了“黑客”侦查队，并积极开展工作，此后分别于1997年和1999年建立了计算机犯罪侦查队和网络犯罪侦查队，并于2000年成立了网络恐怖监控中心，由此韩国成为了“网络侦查强国”。各国纷纷派人前去学习或请韩国人协助取证



中国电子学会计算机取证专家委员会

2005年4月以中国科学院软件研究所为依托单位成立了**中国电子学会计算机取证专家委员会**并召开工作会议。来自中国电子学会、公安部、信息产业部、中国科学院、北京大学、清华大学、中国人民大学、武汉大学、厦门大学、北京市国家安全局、北京市公安局和国内企业界的专家、学者和技术人员共计³⁰余人参加了成立大会。

2007年6月2-3日再次在北京人民警察学院召开工作会议，调整了专家委员会成员，并就知识产权保护和网络欺诈中的计算机取证问题进行学术研讨。

2013年1月19日就电子证据在新形势下的发展问题召开高层次的前瞻性研讨（闭门会议，即非公开）

多次讨论一些热点难点问题，并为我国电子证据法律技术的发展建言献策。



首届全国计算机取证技术研讨会

时间：2004年11月

地点：北京

主办：

- 北京人民警察学院
- 中国科学院软件研究所
- 北京市公安局网络信息安全监察处

- 参加此次会议有来自全国各地的近100名代表。中国科学院、中国人民大学法学院等专家以及来自企业的技术人员和公安系统的专业人员就计算机取证技术的研究现状和发展趋势、计算机取证技术的需求与应用以及电子证据立法的现状与前瞻等问题作了专题报告。研讨会汇集了32篇论文，组成了论文集。这次研讨会对计算机取证技术的理论与实践的研究产生积极的影响，推动了我国计算机取证技术的发展。



第二届全国计算机取证技术研讨会

时间：2006年8月

地点：新疆乌鲁木齐

主办：

- **新疆人民警官人民警察学院**
- **中国科学院软件研究所**
- **新疆维吾尔自治区公安厅网络信息安全监察处**



第三届全国计算机取证技术研讨会

时间：2011年11月

地点：上海

主办：

- 华东政法大学信息学院
- 中国科学院软件研究所



第四届全国计算机取证技术研讨会

- 时间：2014年11月14日至16日
- 地点：上海
- 主办：中国电子学会计算机取证专家委员会
- 承办：华东政法大学



第五届全国计算机取证技术研讨会

- 时间：2015年11月20日至22日
- 地点：北京
- 主办：中国电子学会计算机取证专家委员会
- 承办：中央财经大学

即将召开，欢迎大家积极参加！



第一届国际数字取证与调查技术研讨会

时间：2012年9月21日-2012年9月23日

地点：北京

承办：

中国人民公安大学

CITDC（中国国际人才开发中心）

MeiYa（厦门美亚柏科公司）

ISFS（香港资讯保安及法证公会）



第三届 中国计算机取证技术峰会 2007年会

计算机法证、资讯科技诈骗罪行及讯息保安

讲师: 曹志光先生

Barrister, LLB(Hons.) London , CFE, MIOB, DMS, MIMC, FCMJ
前廉政公署执行处法律及管理调查研究组组长
国际诈骗审查师协会香港分会的主席
香港中文大学诈骗审查专业课程总监等
毅易达亚洲顾问有限公司创办人和行政总裁

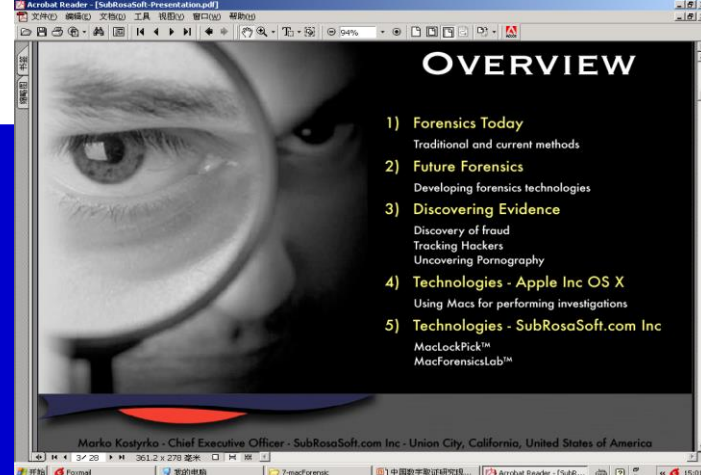
日期: 2007年6月27日

Grant Thornton

第三届中国计算机取证技术峰会
二零零七年六月二十八日

计算机法证个案研究:
确凿的数字证据范例

朗嘉露
美国均富会计师行
法证及调查服务总监



Deloitte.

Network Forensics: Tapping the Network

Jean-François "JF" Legault
Sr. Manager - Analytic & Forensic Technology
China Computer Forensic Conference
June 27, 2007

Audit, Tax, Consulting, Financial Advisory.

X-Ways Forensics 综合取证分析工具

2006-2007最新功能介绍

Stefan Fleischmann, CEO

X-Ways Software Technology AG

Agrippastr. 37-39
50676 Cologne
Germany
Tel.: 0221-420 486 5
www.x-ways.com
mail@x-ways.com



Preparing Workstations for Digital Evidence Collection



BJ Gleason
Associate Professor 副教授
University of Maryland

第三届中国计算机取证技术峰会
2007年会
The 3rd China Computer Forensics Conference (2007)
Beijing, China, June 25-29, 2007

Andy Joyce MSc CISSP EnCE MCSE+I
Manager Digital Forensics
FDR Forensic Data Recovery Inc.

Bus: 1 (250) 382 9700
Toll free: 1 (866) 381 9700

ajoyce@forensicdata.ca

FDR Forensic Data Recovery Inc.
B.C. Lower Mainland Office
9-32442 Geo. Ferguson Way #512
Abbotsford, BC Canada V2S 6H1

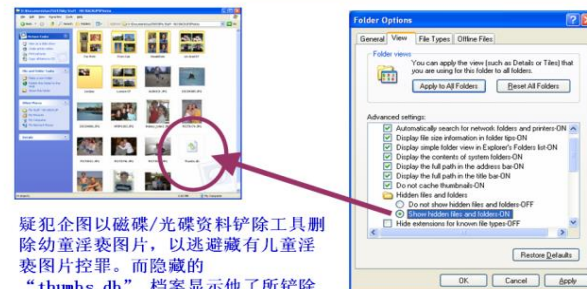
<http://www.forensicdata.ca>

the truth is in there.™

TRACKING USB THUMB DRIVE USAGE

Copyright © 2007 FDR Forensic Data Recovery Inc.
May not be copied or reproduced without the written permission of
FDR Forensic Data Recovery Inc.

个案研究三
从隐藏档案修复非法图像



Grant Thornton

电子取证相关课题

- **国家“十五”科技攻关项目课题**
——**电子数据证据鉴定技术**
- **国家863项目**
——**基于攻击和取证的信息系统安全隐患发现技术和工具，2002年**
- **国家863项目子课题**
——**电子物证保护及分析技术，2002年**
- **国家863项目**
——**云计算环境下的恶意行为检测与取证，2014年**



数字取证面临的7个主要问题



1. 搜集或检查会改变证据的原始状态；
2. 计算机调查和数字证据对法律执行、法庭和立法机关来说是个新生事物；
3. 爆炸性增长的数字媒体密度和普遍深入的计算机平台；
4. 数字数据或隐藏数据的非直观性；
5. 信息技术及广泛应用在日益变化；
6. 合格的取证人员的技能与培训；
7. 数字信息的短暂性（转移、易改）。



总结 — 中国计算机取证

- 我国计算机取证从引进、代理到自主研发，差距还比较大，主要是我国的企业规模小，资本投入不足，产品质量和品种还不多
- 课题研究已经全方位开展，我国科研人员在操作系统的可取证研究、以及可能在BIOS芯片取证方面推出了自主创新的研究成果，但目前缺乏较为集中的数字取证科研团队
- 计算机取证技术的研究有鲜明的国家特点，即国家的性质、法律和制度对于计算机取证技术的研究均具有一定的影响和制约。照搬照抄国外的计算机取证技术和工具的做法是不可取的。结合中国国情的数字取证探索值得大力提倡



提纲

- 概况
- ➔ 研究领域
- 热点难点问题

电子取证的研究领域

- 计算机软硬件技术
- 网络通信技术
- 相关领域专业知识
- 法律法规
- 管理制度
- 标准规范
- 人才教育
- ○ ○ ○ ○ ○ ○

提纲

- 概况
- 研究领域
- ➔ 热点难点问题

电子取证的热点难点问题

- 云计算取证的技术挑战
- 移动取证的技术挑战
- 大数据取证的技术挑战
- 非传统软硬件取证的技术挑战
- 取证与反取证的技术博弈
- 法律法规与技术的结合

云计算取证的技术挑战

云取证技术的国外研究现状

- 2014 年 6 月，美国国家标准与技术研究院（National Institute of Standards and Technology, NIST）云计算取证科学工作组发布了 Draft NISTIR 8006 《NIST 云计算取证科学挑战》，在全球首次系统的总结了云计算生态系统所面临的取证技术挑战，以获得对云计算取证技术挑战的共同理解，并寻求相应的技术和标准予以应对。该文对云计算取证科学进行了定义，并提出了云计算在数据收集、汇总和分析等方面所面临的 65 项技术挑战
- 有了一些相关的论文和研究成果

云取证技术国内研究现状

- **虚拟机取证技术**：其主要原理是使用相关的技术和工具对各类虚拟机中的数据进行提取、分析和保存等操作。虚拟机数字证据的主要来源包括虚拟机硬盘、内存、BIOS 等
- **面向取证的虚拟机迁移技术**：其主要原理是通过对云计算取证的建模，将云计算平台视为由多个虚拟机构成的系统，将其上运行的虚拟机实例作为取证分析对象；再利用现场迁移技术，在虚拟化软件层对虚拟机实例进行信息保全，以保证所迁移镜像文件的内容完整性和一致性
- **虚拟身份追踪与取证技术**：其主要原理针对虚拟化环境中复杂的身份转换机制，按照数字证据的特点和法律要求，通过事前内置虚拟身份追踪与取证机制、事中增强丰富的虚拟身份相关行为审计、事后完善虚拟身份相关证据保全方法，从而构建面向云环境的立体化虚拟身份取证机制，为云计算环境提供符合法律要求的虚拟身份相关证据获取、保全、分析、展示等一体化功能

云计算环境取证的技术挑战

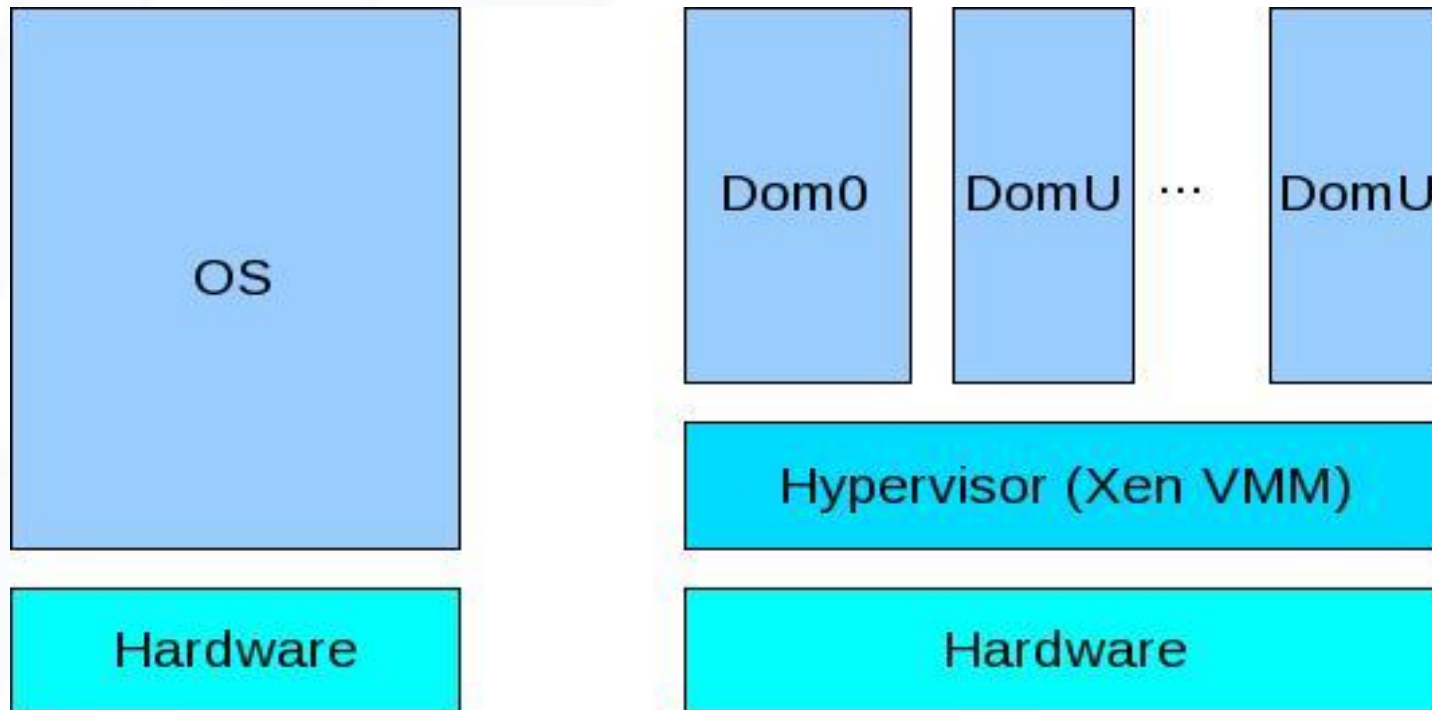
- **难以提取**：虚拟化的大范围使用
- **难以定位**：云端服务器的物理位置可能分散在不同的地方
- **难以分析**：数据格式和描述都是专有的，不是标准化和广泛使用的

我们的云取证框架

---参见谢亚龙同学的硕士毕业论文



Xen体系结构



Hypervisor

- Hypervisor 是位于操作系统和硬件间的一个层次，提供一个让内核运行在其上的虚拟环境。负责运行在其上的虚拟机之间的 CPU 调度和内存管理。
- Hypervisor 对 guest 提供了调用接口：hypercall（类似 linux 里的系统调用）。

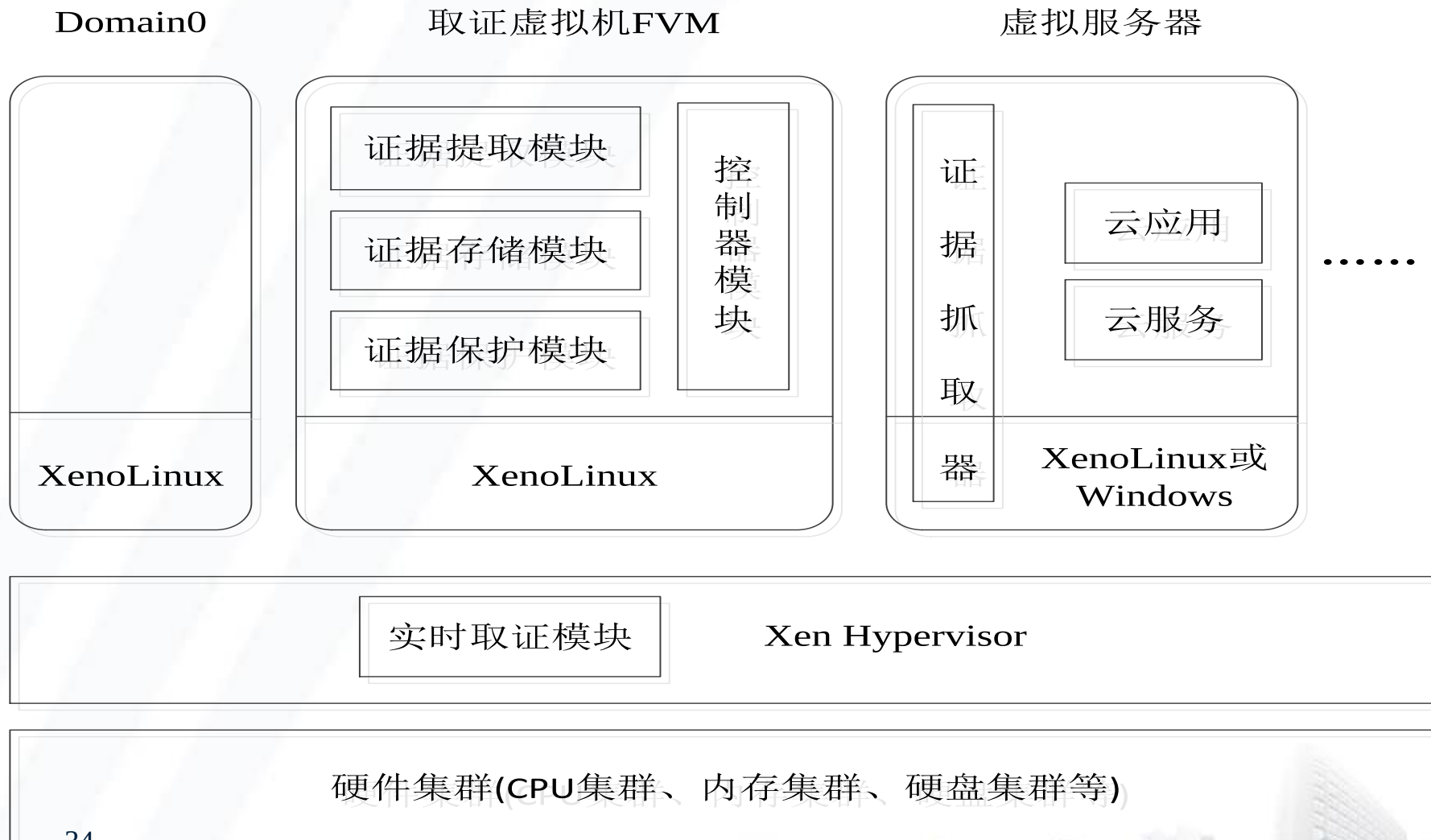


数字取证的五个步骤

- 根据RFC3227(Guidelines for Evidence Collection and Archiving , February 2002 , <http://www.ietf.org/rfc/rfc3227.txt>)可知，数字取证调查主要包括五个步骤，即搜集(collection)、提取(extraction)、分析(analysis)、报告(presentation)及文档化(documentation)。在云环境中，“搜集”是最关键的步骤，也是最难的步骤。



取证框架系统架构图



正在进行的项目的研究内容：云环境下的取证技术



主要创新点

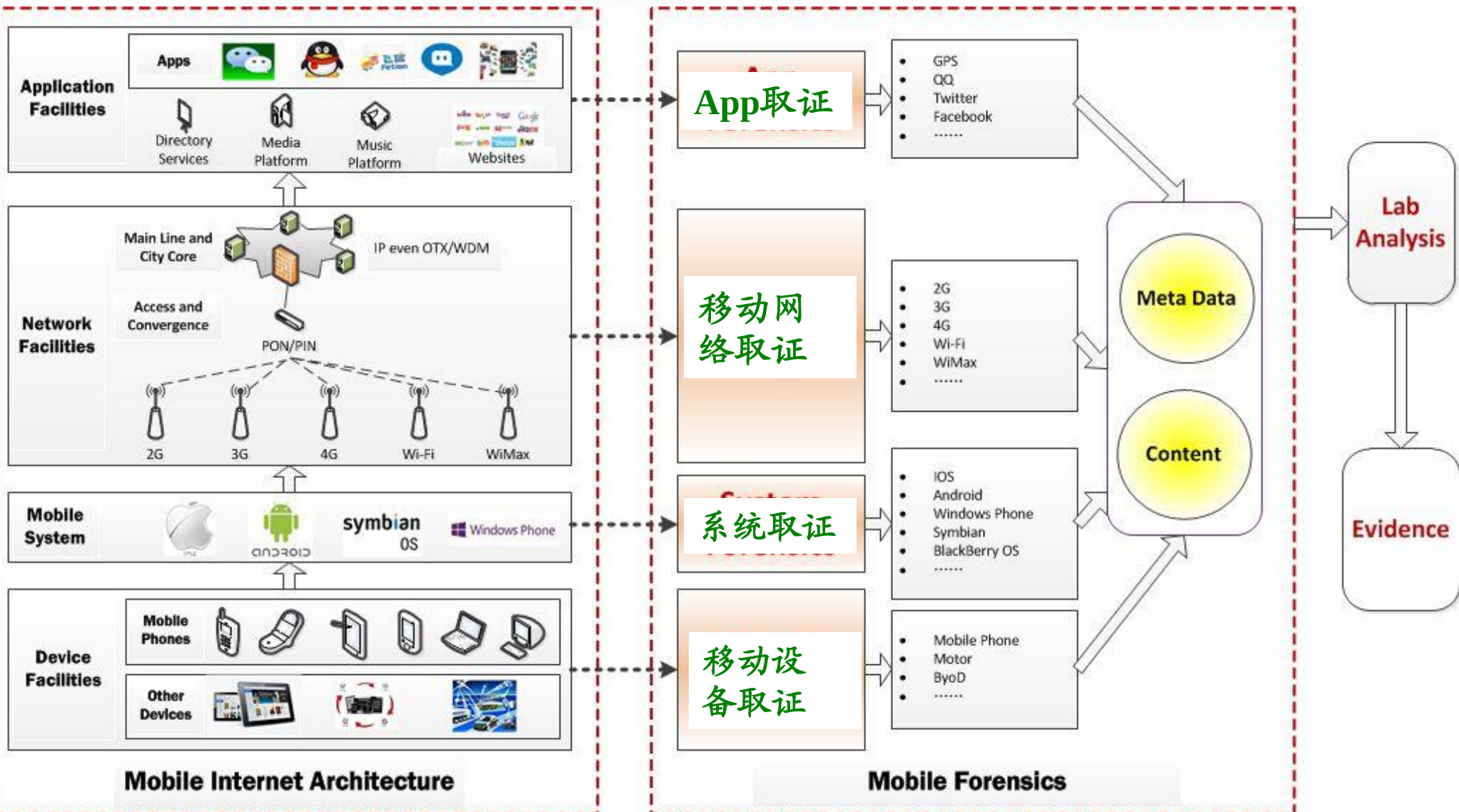
提出一个IaaS云服务模型下的取证框架
设置一个专门用来存储、分析证据信息的取证虚拟机FVM

提出适应我国执法部门的云环境下取证模型
结合公安实务部门工作特点，研发相应产品

提出一种新的智能终端在线取证的方法
解决智能终端密码保护系统难以破解、证据难以完整获取、
证据的智能化关联分析程度不高等问题

移动取证的技术挑战

移动取证



移动取证技术研究现状

- 以 Android 和苹果系列智能终端得到大规模使用前后为界限，移动取证技术的研究可以分为两个发展阶段
- 早期研究（2001年-2007年）：不同种类的手机采用的存储格式和数据处理方式没有统一规范，因而取证工具无法适用所有型号的手机
- 近期研究（2007 年以后）
 - 国内外早期的智能终端取证技术研究开发机构也开始转向 iOS 和 Android 等新型智能终端方面，推出了一些工具
 - 国外目前对于这些新型智能终端电子取证技术的研究主要还处于实用需求方面，从取证模式、取证标准、取证技术的全面性等角度都存在诸多的不足

NIST'S Guidelines on Mobile Device Forensics

移动设备取证指南

NIST Special Publication 800-101
Revision 1

Guidelines on Mobile Device Forensics

Rick Ayers
Sam Brothers
Wayne Jansen

<http://dx.doi.org/10.6028/NIST.SP.800-101r1>

NIST
National Institute of
Standards and Technology
U.S. Department of Commerce

NIST Special Publication 800-101
Revision 1

Guidelines on Mobile Device Forensics

Rick Ayers
*Software and Systems Division
Information Technology Laboratory*

Sam Brothers
*U.S. Customs and Border Protection
Department of Homeland Security
Springfield, VA*

Wayne Jansen
*Booz-Allen-Hamilton
McLean, VA*

<http://dx.doi.org/10.6028/NIST.SP.800-101r1>

May 2014



U.S. Department of Commerce
Penny Pritzker, Secretary

National Institute of Standards and Technology
Patrick D. Gallagher, Under Secretary of Commerce for Standards and Technology and Director

Table of Contents

TABLE OF CONTENTS	V
LIST OF FIGURES	VII
LIST OF TABLES	VIII
EXECUTIVE SUMMARY	IX
1. INTRODUCTION	1
1.1 PURPOSE AND SCOPE	1
1.2 AUDIENCE AND ASSUMPTIONS	1
1.3 DOCUMENT STRUCTURE	1
2. BACKGROUND	3
2.1 MOBILE DEVICE CHARACTERISTICS	3
2.2 MEMORY CONSIDERATIONS	5
2.3 IDENTITY MODULE CHARACTERISTICS	7
2.4 CELLULAR NETWORK CHARACTERISTICS	10
2.5 OTHER COMMUNICATIONS SYSTEMS	12
3. FORENSIC TOOLS	15
3.1 MOBILE DEVICE TOOL CLASSIFICATION SYSTEM	15
3.2 UICC TOOLS	23
3.3 OBSTRUCTED DEVICES	24
3.4 FORENSIC TOOL CAPABILITIES	25
4. PRESERVATION	27
4.1 SECURING AND EVALUATING THE SCENE	27
4.2 DOCUMENTING THE SCENE	28
4.3 ISOLATION	28
4.4 PACKAGING, TRANSPORTING, AND STORING EVIDENCE	33
4.5 ON-SITE TRIAGE PROCESSING	34
4.6 GENERIC ON-SITE DECISION TREE	35
5. ACQUISITION	37
5.1 MOBILE DEVICE IDENTIFICATION	37
5.2 TOOL SELECTION AND EXPECTATIONS	39
5.3 MOBILE DEVICE MEMORY ACQUISITION	40
5.4 TANGENTIAL EQUIPMENT	45
5.5 CLOUD BASED SERVICES FOR MOBILE DEVICES	46
6. EXAMINATION AND ANALYSIS	48
6.1 POTENTIAL EVIDENCE	48
6.2 APPLYING MOBILE DEVICE FORENSIC TOOLS	50
6.3 CALL AND SUBSCRIBER RECORDS	52

7. REPORTING	56
8. REFERENCES	59
8.1 BIBLIOGRAPHIC CITATIONS	59
8.2 FOOTNOTED URLS	63
APPENDIX A. ACRONYMS	65
APPENDIX B. GLOSSARY	68
APPENDIX C. STANDARDIZED CALL RECORDS	73
APPENDIX D. ONLINE RESOURCES FOR MOBILE DEVICE FORENSICS	76

移动设备取证过程

1

保护证据 Preserve evidence

Evidence preservation is the process of securely maintaining custody of property without altering or changing the contents of data that reside on devices and removable media.

2

获取证据 Acquisition

Acquisition is the process of imaging or otherwise obtaining information from a mobile device and its associated media.

3

鉴定与分析 Examination and Analysis

The examination process uncovers digital evidence, including that which may be hidden or obscured. The analysis process differs from examination in that it looks at the results of the examination for its direct significance and probative value to the case.

4

报告 Reporting

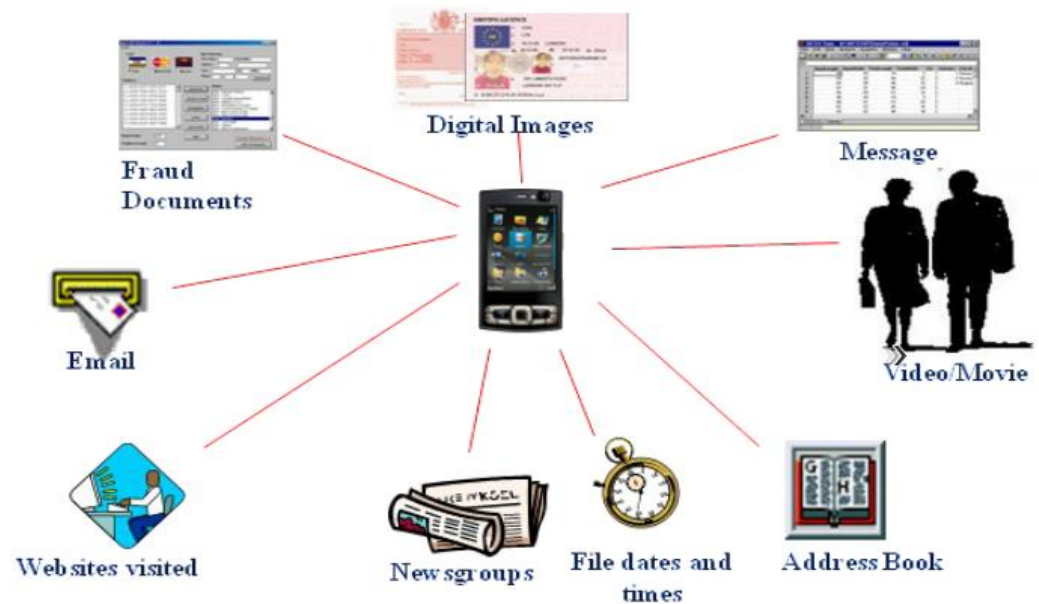
Reporting is the preparing a detailed summary of all the steps taken and conclusions reached in the investigation of a case.

移动设备取证 (Mobile Devices Forensics)

从移动设备中可以提取很多情报信息。。。



-  Cell phone
-  Address book
-  Planner & Organizer
-  Messenger
-  Photo & Video camera
-  GPS navigator
-  Web client
-  Platform for 3rd party apps



移动设备取证分类



各种移动设备取证的软件工具

Device Forensics Tools



移动取证的技术挑战

- **突破权限限制**
- **内存提取和分析**
- **加密备份文件的解密还原**
- **对传感器的数据源进行鉴定分析**

大数据取证的技术挑战

大数据取证技术国外研究现状（1）

- **Sleuthkit on Hadoop 方法：** **Sleuthkit onHadoop** 是一个开源项目，该方案的主要原理是通过在 Hadoop 框架上来运行 Sleuthkit，以实现 Sleuthkit 工具的集群化分析，从而提高大数据取证分析的效率。该项目创建了一套运行 Sleuthkit 的 Hadoop 框架，包含读入（Ingest）、分析（Analysis）、报表（Reporting）等三个阶段，并可以实现现在云计算环境中的部署；不过，当前该项目相关功能实现还很不完善，项目进展也较为缓慢

大数据取证技术国外研究现状（2）

- **分布式取证系统方法**：英国南威尔士大学的 Nick Pringle 提出了一套分布式取证系统方案，并在 DFRWS 的 2014 年欧洲会议上进行了介绍。该方案使用了 FUSE 分布式取证文件系统和 Fclusterfs 取证集群文件系统进行分布式取证分析，从而打破了传统磁盘镜像集中存储所带来的读写性能瓶颈。FUSE 通过虚拟文件系统（Virtual File System）实现了对分布式文件系统的统一封装内容抽样方法

大数据取证技术国外研究现状（3）

- **内容抽样方法**：美国海军研究院的 Simson L.Garfinkel提出了一种用于快速分析硬盘大数据的内容抽样方法。通过构建专门的数据采样算法，可以快速分析出磁盘中各类数据的组成比例及其位置，比如：空扇区、加密文件、视频、html 文件、word 文档等，从而对所关注的取证数据实现快速定位和取证分析

大数据取证的技术挑战

- **数据量巨大：电子取证提取和分析需要大量计算资源和存储资源**
- **数据类型复杂：**
 - 大量结构化、半结构化和非结构化数据并存；
 - 数据类型包含多种数据类型混合（文档、数据库、音视频）
 - 对数据处理能力和关联分析要求高
- **证据价值密度低：如何迅速完成电子证据的精确提取分析**

非传统软硬件取证的技术挑战

非传统软硬件技术的特点及面临的挑战

■ 非传统软硬件特点

- SSD 盘、BIOS 固件、加密 U 盘、汽车电子、舰船电子、IPv6 协议等
- 技术往往具有自身的独特性

■ 取证面临挑战

- **SSD盘取证**
 - 特有的垃圾回收和TRIM指令导致无法进行传统的数据恢复
 - 加电情况下，没有外界读写操作也会自动发生变化
- **BIOS固件取证**：属于当前数字取证过程中的一个盲区
- **IPv6 软硬件取证**：IPv6 协议在 IP 地址编码、协议原理等方面与 IPv4 协议有诸多不同，部分取证工具无法正确实现对 IPv6 软硬件的取证分析

取证与反取证的技术博弈

反取证技术带来的挑战

- **数据覆盖方法**：数据安全删除、元数据覆盖、阻止数据生成等
- **数据隐藏方法**：数据加密、网络协议加密、程序加壳、隐写术、隐蔽通道等
- **对抗取证分析**：恶意程序可以检测是否有人在进行取证分析，一旦发现则销毁证据、自动退出，或者杀掉取证分析进程
- **拟态防御**：MTD(Moving Target Defence)带来的取证困难
- **去中心化**：点对点通信的取证问题



谢谢大家
Thanks